Module 02: Reconnaissance

Social Engineering in Reconnaissance

Project Athena

Social Engineering for Recon

Definition

Getting information from **people** that you can't get from systems.

- This lecture: information gathering only
- Full coverage: Module 22


Exploit
the firewall
Call
the
receptionist
Memegen.link

Why It Works

- People want to be helpful
- People trust authority
- People are busy and under pressure
- Perfect firewall, one chatty employee


IT WAS NEVER A FIREWALL PROBLEM
IT WAS A RECEPTIONIST PROBLEM
Memegen.link

Pretexting

The Pretext

A believable story that justifies the question

IT support, vendor, survey, new hire, potential customer.

- Research first: real names, real jargon
- Have answers ready for “who are you again?”


IT SUPPORT
NYPD
IT SUPPORT
Memegen.link

What Attackers Ask For

- OS, antivirus, VPN, MFA in use
- Email and username format
- Badge system, visitor policy
- Working hours, who is on vacation

Channels

Phone (Vishing)

- Real-time, can adapt to answers
- Call when people are busy
- Start small, escalate

Email

- “Five-minute technology survey”
- Scales to hundreds of targets
- Looks for **answers**, not clicks

In Person

- Tailgating through the door
- High-vis vest and clipboard
- Whiteboards, sticky notes, badges on lanyards


PASSWORD ON A STICKY NOTE UNDER THE KEYBOARD
IT AIN'T MUCH, BUT IT'S HONEST WORK
Memegen.link

Social Media

- Office photos: screens, badges, whiteboards
- “Finally finished our Palo Alto rollout!”
- Complaints about internal systems

Psychology

Cialdini's Six Levers

1. **Authority** – “This is corporate IT”
2. **Reciprocity** – “I helped you last time”
3. **Social proof** – “Your colleagues already did”
4. **Scarcity** – “Need it by end of day”
5. **Liking** – common ground, compliments
6. **Consistency** – small yes, then bigger yes

Urgency switches off thinking.

Defense

Red Flags

- Urgent, unusual, secret
- Asks you to skip procedure
- Verifies **their** identity by asking **you** questions



What To Do

- Hang up, call back on a known number
- Follow policy, escalate when unsure
- Report attempts, even failed ones
- Clean desk, challenge strangers, don’t hold the door

Rules

Authorization

Written rules of engagement

Who may be targeted, which channels, what is off limits.

- Impersonating officials may be illegal
- Recording calls needs consent
- Debrief people as a lesson, never as punishment

Remember

- People leak what systems protect
- Pretext + psychology = information
- Verify, slow down, report
- Authorization first

Resources

- “The Art of Deception” by Kevin Mitnick
- “Influence” by Robert Cialdini
- Module 22 - Social Engineering

Module 02: Reconnaissance

Social Engineering in Reconnaissance

Project Athena